

-
File No.: EXP202307987

Sanctioning Procedure No. PS/00395/2023

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection on April 27, 2023. The complaint is initially directed against the law firm RECATALA AGRAMUNT ABOGADOS Y ECONOMISTAS (hereinafter, Law Firm-RA).

The reasons for the complaint are literally as follows:

“This law firm has had a security breach by sending commercial information about its services and instead of using the Bcc field, they used the Cc field when including the emails of the recipients and making a mass mailing, among which I am included, exposing the email of everyone, many of whom can have their identity inferred from their email that has been made public and, therefore, this is compromised.”

Along with the complaint, the header of the email sent on 04/24/2023 by ***EMAIL.1 to 95 recipients - among whom is the complainant - is provided, whose email addresses appear visible since they were sent as ordinary copy (Cc), instead of blind copy (Bcc). However, the content of the email sent is not provided.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), on 06/12/23, the complaint was forwarded to the respondent party for analysis and to inform this Agency within one month of the actions taken to comply with the requirements established in the data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP) by electronic notification to the unique electronic address of Law Firm-RA, was not collected by the responsible party within the availability period, being understood as rejected in accordance with the provisions of Article 43.2 of the LPACAP on 06/23/2023, as stated in the certificate in the file. Although the notification was validly carried out by electronic means, considering the procedure completed in accordance with the provisions of Article 41.5 of the LPACAP, an informational copy was sent by postal mail, which was duly notified on 07/12/2023. In this notification, Law Firm-RA was reminded of its obligation to communicate electronically with the Administration, and it was informed of the means to access such notifications, reiterating that, henceforth, notifications would be made exclusively by electronic means.

THIRD: On July 27, 2023, in accordance with Article 65 of the LOPDGDD, the complaint filed by the complainant was admitted for processing.

FOURTH: On July 31, 2023, a response letter was received by this Agency from Mr. B.B.B., with NIF ***NIF.1, stating that he presents allegations in his own name and representation, but makes statements in defense of Law Firm-RA, indicating, in summary, that this firm sends commercial communications only to clients who register on the various payment portals to which they are subscribed as a law and economics firm, where the subscribing individuals register their personal data, acting under the protection of Article 21 of Law 34/2002, of July 11, on Information Society Services (hereinafter, LSSI).

Along with the allegations, a copy of the header and body of the email sent to the complainant on April 23, 2023, is provided. It is observed that this was sent to 95 recipients whose email addresses appear visible without using the blind copy functionality, and that it is a commercial email advertising the professional services of Law Firm-RA.

No accreditation of the representation of the aforementioned Law Firm-RA, to which the complaint was directed, is attached.

FIFTH: Requested the NIF number of Law Firm-RA from the Tax Agency, it stated on October 24,

2023, that it has no data in the name of the referred entity.

SIXTH: On October 25, 2023, a letter was sent to Mr. B.B.B., requiring him to prove whether he acts on behalf of the referred Law Firm-RA and to provide the NIF number of the referred entity. Sent by electronic notification, this was rejected, which is why the requirement was reiterated by postal means to his address, being finally notified on December 12, 2023.

SEVENTH: On December 12, 2023, Ms. C.C.C., with NIF ***NIF.2, submitted a letter on behalf of the entity COYARE SLU, with NIF B12931754, stating that COYARE SLU corresponds to the referred Law Firm-RA, and says to grant powers of representation to B.B.B. to make decisions on behalf of the company. The deed of incorporation of the company COYARE SLU is attached, which certifies that the declarant is the sole administrator.

EIGHTH: According to the report obtained from the AXESOR tool dated December 26, 2023, the entity COYARE SLU is a small company incorporated as a limited liability company in 2014, whose last reported turnover is that which is recorded for the year 2019, amounting to (...) euros.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/19

NINTH: On March 27, 2024, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the complained party for the commission of an alleged infringement of Article 5.1.f) of the GDPR, in accordance with the provisions of Articles 63 and 64 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), for the alleged infringement of Article 5.1.f) of the GDPR and Article 32 of the GDPR, classified under Article 83.5 of the GDPR and Article 83.4 of the GDPR.

TENTH: On April 18, 2024, a communication initiating sanctioning proceedings was sent to the complaining party.

ELEVENTH: The aforementioned initiation agreement was notified in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP). B.B.B. submitted a written statement of allegations on behalf of the complained entity, in which, in summary, he states the following:

- Change of interpretation of Article 21.1 of the LSSI following the Judgment of June 15, 2011, which prohibits the sending of unsolicited or expressly authorized commercial communications by their recipients. According to the complained party, in said Judgment, the A.N departs from the consent requirement established by Article 21 and has interpreted that in the event that a user receives several commercial communications from a third party without having given their prior and express consent, but without opposing the processing, only the first of the commercial communications sent would be sanctionable, since by not opposing the receipt of subsequent commercial communications, the A.N considers that the user would have given their consent. It is noted that the Spanish Agency for Data Protection (AEPD) has begun to apply the criterion established by the A.N since September 2014, mentioning two Resolutions from the same.

- Prescription of actions and applicable sanctions:

It is stated in this regard that: "Given this new interpretation of the LSSI, since only the first commercial communication is reportable, if the user does not oppose subsequent commercial communications, there is a possibility that the action to report that first communication may prescribe, since the prescription period for minor sanctions is 6 months from the receipt of the first communication (Article 45 of the LSSI)." The complained party understands that this is a minor infringement, and therefore it would be prescribed.

It is clarified in this regard that it is understood that Mr. B.B.B. acts as a representative of the complained entity, whose representation was accredited by a document submitted by the sole administrator of the company during the phase of transferring the file, although he is warned of the need to submit documents through the electronic registry as a representative and not as an interested

party.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

4/19

TWELFTH: On June 4, 2024, a Proposal for Sanctioning Resolution was issued by the instructor of the proceedings, which was notified on June 15, 2024, to the complained party, granting a period of 10 working days for them to allege whatever they deemed appropriate in their defense and to present the documents and information they consider pertinent.

As of today, the deadline granted has passed, and no allegations or documentation have been submitted in response to the Proposal for Resolution.

From the actions carried out in the present proceedings and the documentation in the file, the following has been established:

PROVEN FACTS

FIRST: It is accredited and recognized by the complained party that on April 24, 2023, it sent an email addressed to 95 recipients - including the complainant - which contained commercial advertising for the services of Bufete-RA, in which the 95 email addresses appeared visible in ordinary copy (Cc), instead of in blind copy (Bcc).

SECOND: According to the deed submitted on December 12, 2023, by Ms. C.C.C., with NIF ***NIF.2, the complained entity, which provides legal advisory services under the commercial name Bufete-Ra, is registered and constituted under the name COYARE SLU, with NIF number B12931754.

THIRD: According to the report issued through the AXESOR tool on December 26, 2023, the entity COYARE SLU is a small company constituted as a limited liability company in 2014, whose last reported turnover is that which is reported for the year 2019, amounting to (...) euros.

LEGAL GROUNDS

I

Competence and procedure.

In accordance with and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

5/19

II

Preliminary Issues

The email address is considered a personal data whose processing is subject to the regime established in the GDPR, as well as its implementing provisions, in accordance with the provisions of Article 4.1, 2, and 7 of the GDPR, which states the following:

"Article 4 Definitions

For the purposes of this Regulation, the following definitions shall apply:

1) 'personal data': any information relating to an identified or identifiable natural person ('the data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or one or more specific elements of the physical, physiological, genetic, mental, economic,

cultural, or social identity of that natural person;

2) 'processing': any operation or set of operations which is performed on personal data or on sets of personal data, whether or not by automated means, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment, combination, restriction, erasure or destruction; (...)

7) 'controller' or 'data controller': the natural or legal person, public authority, agency, or other body which, alone or jointly with others, determines the purposes and means of the processing; where the law of the Union or of the Member States determines the purposes and means of processing, the controller or the specific criteria for its designation may be provided for by the law of the Union or of the Member States (...)"

In this case, according to the provisions of Article 4 of the GDPR, from the documentation in this file, it is inferred that the entity COYARE SLU is responsible for having processed personal data of 95 individuals to whom a commercial email with advertising for professional services has been sent. This entity provides its commercial and legal advisory services under the trade name Bufete-Ra, as deduced from the deed of incorporation of the company and the document submitted by its sole administrator dated June 26, 2023.

From the content of the written allegations submitted by Mr. B.B.B. on July 31, 2023, responding to the first transfer made by this Agency to Bufete-RA, and which has subsequently appeared as its representative.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
6/19

After the initiation of the present sanctioning file, it is expressly acknowledged that the email without a blind copy referred to in this file was sent on behalf of the so-called Bufete-RA, to send advertisements for its professional services. In this document, it is stated that it is a common practice of the company to send commercial communications to clients who register on the various paid portals to which they are subscribed as a law firm and economists, where the subscribing individuals register their personal data.

Therefore, to send the mass email on April 24, 2023, to 95 recipients, the entity must have carried out several operations of personal data processing listed in the aforementioned Article 4.2 of the GDPR, such as the collection, registration, or extraction of the email addresses of the 95 recipients, as well as their dissemination or communication by transmission when sending them via mass email, without using the blind copy functionality.

Subsequently, in the written allegations against the initiation agreement presented by Mr. B.B.B., as the representative of the entity, no statements have been made that deny the facts acknowledged in the first response to the transfer, only questioning whether the sending of such an email infringed Article 21.1 of the LSSI, and whether this was time-barred. Since then, no further allegations have been made in this regard.

By virtue of this, it is confirmed that the entity in question carried out various operations of processing the personal data of the recipients of said commercial email, so there is no doubt that the data protection regulations provided for in the GDPR were fully applicable, regardless of whether it must also comply with other possible applicable regulations, such as the LSSI, when sending commercial emails.

On the other hand, the sole administrator of the company states in her document of June 23, 2023, that the entity COYARE SLU operates under the name Bufete-RA, which is consistent with the documentation provided by her, where it is noted that COYARE SLU is a limited liability company that includes among its corporate purposes the activity of providing professional advisory services to companies, professionals, and individuals. Therefore, there is also no doubt that COYARE SLU has legal personality and is responsible for the operations of personal data processing carried out by the aforementioned entity when sending the referred commercial emails, using the name Bufete-RA.

For all the above reasons, as has been confirmed after the instruction carried out, COYARE SLU was responsible for the processing of the personal data that were unlawfully disclosed through the aforementioned email, and thus it is the entity to which the present sanctioning procedure must be addressed in accordance with the provisions of Article 70.1 a) of Organic Law 3/2018, of December 5, on the protection of personal data and the guarantee of digital rights (hereinafter, LOPPDD):

“Article 70. Responsible subjects.

1.

They are subject to the sanctioning regime established in Regulation (EU) 2016/679 and in this organic law: a) The responsible parties of the...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/19

treatments. b) The controllers of the treatments. c) The representatives of the controllers or processors not established in the territory of the European Union. d) The certification entities. e) The accredited entities supervising the codes of conduct. (...).”

III

Response to the allegations made

Following the initiation of this sanctioning procedure, which imputes to the respondent the possible commission of two administrative infractions typified in articles 5.1.f) and 32 of the GDPR, the respondent has only submitted a written statement of allegations against the initiation agreement, dated May 2, 2024, without presenting new allegations or documentation following the Proposal for Resolution issued by the instructor.

Therefore, it is appropriate to respond only to the allegations made against the initiation agreement, in which only the following reasons were stated for why COYARE SLU (Bufete Ra) should not be held responsible for the sending of the mass email referred to in this file:

- Change in the interpretation of article 21.1 of the LSSI following the Judgment of June 15, 2011, which prohibits the sending of unsolicited commercial communications that have not been requested or expressly authorized by their recipients. According to the respondent, in this Judgment, the A.N departs from the requirement of consent established by article 21, and has interpreted that in the case where a user receives several commercial communications from a third party without having given their prior and express consent, but without opposing the processing, only the first of the commercial communications sent would be sanctionable, since by not opposing the receipt of subsequent commercial communications, the A.N considers that the user would have given their consent. It is noted that the Spanish Agency for Data Protection (AEPD) has begun to apply the criterion established by the A.N since September 2014, mentioning two Resolutions from the same.

- Prescription of actions and applicable sanctions:

It is stated in this regard that: “In light of this new interpretation of the LSSI, since only the first commercial communication is reportable, if the user does not oppose subsequent commercial communications, there is a possibility that the action to report that first communication may prescribe, since the prescription period for minor sanctions is 6 months from the receipt of the first communication (article 45 of the LSSI).” The respondent understands that this is a minor infraction, and therefore it would be prescribed.

In this sense, as highlighted in the Proposal for Resolution, the respondent does not defend against the infractions that are the subject of this.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/19

procedure, and which refer to its non-compliance as the data controller, regarding two obligations established in the GDPR, which are: (i) the obligation set forth in Article 5.1(f) of the GDPR, for having

breached the controller's duty of confidentiality concerning the personal data of the recipients of these emails, (ii) and Article 32 of the GDPR for failing to implement adequate security measures to prevent such mass emails from being sent without using the blind copy functionality.

Both arguments contained in the written allegations were defended against a possible non-compliance and infringement of Article 21.1 of the LSSI, stating that: (i) the law firm was entitled to send the commercial communication of April 23, 2023, without needing to obtain prior express consent from the recipients as required by the aforementioned provision; (ii) and that the possible infringement of the mentioned Article 21 of the LSSI would be time-barred, as it was, in their opinion, a minor infringement that prescribes after 6 months from the sending of the email.

However, neither the Initiation Agreement nor the Proposal for Resolution of this sanctioning procedure has ever attributed an infringement of Article 21.1 of the LSSI. Moreover, the Initiation Agreement made no reference to the fact that the sending of said email required prior consent from the 95 recipients, a matter that was not disputed. This issue was also not the subject of the complaint filed. The Proposal for Resolution clarified this particular, clearly stating that the arguments presented were not defended against the infringements actually attributed, and therefore, should be dismissed. Nevertheless, despite this, no allegations have been submitted following the Proposal.

Thus, as pointed out by the Proposal for Resolution, and as endorsed by this Resolution:

“Without prejudice to the fact that the requirements set forth in the aforementioned provision are applicable to the sending of the email referred to in this procedure, since it had a commercial content, what is being judged in this procedure is whether the respondent complied with the requirements imposed by the GDPR for processing the personal data that were included in ordinary copy within said email.

In this regard, given that the respondent has acknowledged having sent the email to 95 recipients whose email addresses appeared visible in ordinary copy, there is no doubt that the attributed infringements have been committed, as it is evidenced that:

- The respondent did not comply with the obligations set forth in Article 5.1(f) of the GDPR, by revealing the email addresses of 95 recipients to the other recipients of the email who did not have the right to access such information.
- The respondent did not have the security measures referred to in Article 32 of the GDPR, which would have prevented the sending of emails addressed to more than one recipient without using the blind copy functionality.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
9/19

It should be noted that in its written submission dated July 31, 2023, the respondent stated the following: “this office sends commercial communications only to clients who register on the various payment portals to which they are subscribed as a law firm and economists, where individuals who subscribe register their personal data, acting under the protection of Article 21 of Law 34/2002, of July 11, on Information Society Services (hereinafter, LSSI).” Along with its submission, the respondent provided the same header and body of the email that was submitted by the claimant, which implies acknowledgment of its entire content, including the fact that the 95 email addresses referred to in this procedure were visibly displayed.

In its allegations dated May 3, 2024, regarding this initiation agreement, it does not deny having sent said email and defends itself against a possible breach of Article 21 of the LSSI, which is not the subject of debate in this procedure, without providing any evidence or argument relating to the two infringements of the GDPR whose commission is being adjudicated.

Even after this clarification, and having the respondent a further opportunity to make allegations regarding the Proposal for Resolution, and to express itself concerning the alleged breach of Articles 5.1.f) and 32 of the GDPR, it has not presented any allegations or documentation that contradicts the proven facts in this procedure, even after more than 3 months since the Proposal was notified to it. Therefore, following the instruction carried out, it is appropriate to consider proven the facts from which

the breach of both obligations to maintain the confidentiality of personal data and to adopt appropriate security measures by the respondent as the data controller derives, and to confirm the commission of the two infringements attributed in the initiation agreement of this sanctioning procedure, in the terms set forth in the following Legal Grounds of this Resolution.

IV

Breach of Article 5.1.f) of the GDPR

As indicated in the previous Legal Grounds, the GDPR is applicable to the processing of personal data that has been collected/registered/extracted and communicated by COYARE SLU, regardless of the fact that the email sent contains a commercial communication subject to the regulations of the LSSI, the data controller of the personal data included in that email is also subject to compliance with the principles and obligations set forth in the GDPR.

One of the fundamental principles is the so-called Principle of Confidentiality of data, contained in Article 5.1.f) "Principles relating to processing" of the GDPR, which establishes that:

"1. Personal data shall be: (...)

f) processed in such a way as to ensure an adequate level of security of personal data, including protection against unauthorized or unlawful processing and

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/19

against its loss, destruction, or accidental damage, through the application of appropriate technical or organizational measures ("integrity and confidentiality")."

Article 4, paragraph 12 of the GDPR broadly defines "personal data security breaches" (hereinafter security breach) as "all breaches of security that lead to the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data."

In this case, the mass email sent on April 24, 2023, to 95 recipients with commercial advertising from Bufete-RA (COYARE SLU), constitutes a clear security breach, classified as "unauthorized communication" of the email addresses of the recipients included in the ordinary copy, due to the failure to use the blind carbon copy functionality, thereby committing an infringement of the confidentiality principle of this data regulated in Article 5.1.f) of the GDPR.

As previously stated, the respondent acknowledges having sent the aforementioned email to all the recipients listed therein and does not deny that their email addresses appeared in the ordinary copy, without using the blind carbon copy functionality. In none of the documents submitted does it provide any evidence or argumentation regarding the possible commission of this infringement; rather, it acknowledges having sent the email under these conditions, confirming that the respondent violated the Principle of Confidentiality by disclosing this personal data (email) to all those included as recipients in the ordinary copy, who were not authorized to know the same.

In conclusion, in accordance with the proven facts in this procedure, it is considered that the respondent entity has committed an infringement of Article 5.1.f) of the GDPR, for unlawfully disclosing the email addresses of the 95 recipients that appear visible in the aforementioned email.

V

Classification and qualification of the infringement of Article 5.1.f) of the GDPR

The violation of Article 5.1.f) of the GDPR constitutes the commission of the infringement classified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" provides (the underlining is ours):

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)"

C/ Jorge Juan, 6

11/19

For the purposes of the statute of limitations for infringements, Article 72 “Infringements considered very serious” of the LOPDGDD applies, which indicates (the underlining is ours):

“1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and shall prescribe after three years, which constitute a substantial violation of the articles mentioned therein and, in particular, the following:

a) The processing of personal data violating the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)”

VI

Sanction for the infringement of Article 5.1.f) of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of the initiation of the sanctioning procedure, and without prejudice to what results from the instruction, it is appropriate to grade the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR.

“2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure for those contemplated in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

- a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of affected parties and the level of damage and harm suffered;
- b) the intent or negligence in the infringement;
- c) any measures taken by the controller or processor to mitigate the damage and harm suffered by the affected parties;
- d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have applied under Articles 25 and 32;
- e) any previous infringement committed by the controller or processor;

C/ Jorge Juan, 6

12/19

f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;

g) the categories of personal data affected by the infringement;

h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor notified the infringement and, if so, to what extent;

i) when the measures indicated in Article 58(2) have previously been ordered against the controller or processor in relation to the same matter, compliance with such measures;

j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42; and

k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.”

It is also considered appropriate to adjust the sanction to be imposed in accordance with the criteria established in paragraph 2 of Article 76 “Sanctions and corrective measures” of the LOPDGDD:

“According to the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

a) The continued nature of the infringement.

b) The link between the infringer's activity and the processing of personal data.

- c) The benefits obtained as a result of the commission of the infringement.
 - d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
 - e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
 - f) The impact on the rights of minors.
 - g) Having, when not mandatory, a data protection officer.
 - h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any interested party.”
- In the present case, the following aggravating circumstances can be applied:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

13/19

(i) The one provided for in Article 83.2.a) of the GDPR: “The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of affected parties and the level of damage suffered.” Since the email revealed a personal data (email address) of 95 recipients.

(ii) The one provided for in Article 83.2.b) of the GDPR, relating to: “The intent or negligence in the infringement,” given that despite the absence of intent or malice, there is a serious lack of diligence on the part of the responsible company regarding its duty to protect the confidentiality of the personal data of the individuals included in this mass email without concealing their email addresses.

In this regard, the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, special consideration must be given to the professionalism or lack thereof of the subject, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard.

The STS of 5/06/1998 requires professionals in the sector “a duty to know the applicable rules in particular.” In similar terms, among others, the SSTs of 2/03/1999 and 17/09/1999 state that entities that, due to their activity, are accustomed to processing personal data must be especially diligent and careful when carrying out operations with them and must always opt for the interpretation most favorable to safeguarding the fundamental right to data protection (as repeatedly stated by the National Court, among others in the judgment of 26/11/2008).

(iii) The one set out in Article 76.2 b) of the LOPD: “The link between the infringer’s activity and the processing of personal data,” since the entity COYARE SLU is dedicated to providing legal and economic advisory services to companies and individuals, which is a professional activity subject to the duty of confidentiality regarding the individuals registered on its payment portals, where numerous personal information about its participants is collected.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPD allows for the imposition of a fine of €2,000 (TWO THOUSAND EUROS) regarding the infringement committed by violating the provisions of Article 5.1.f) of the GDPR.

VII

Article 32 of the GDPR

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

14/19

Any data processing operations manager is subject to the duty to implement appropriate technical and organizational measures necessary to ensure an adequate level of security for the personal data being

processed in their organization.

Thus, Article 32 "Security of processing" of the GDPR establishes the following:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying likelihood and severity of risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others: a) the pseudonymization and encryption of personal data; b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services; c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident; d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

Adherence to an approved code of conduct pursuant to Article 40 or an approved certification mechanism pursuant to Article 42 may serve as a factor to demonstrate compliance with the requirements set out in paragraph 1 of this article.

The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data on instructions from the controller, unless required to do so by Union or Member State law."

The respondent has acknowledged in its letter dated July 31, 2024, that it sent said mass email to 95 recipients revealing their email addresses by putting them in plain copy, instead of using the blind carbon copy functionality, as should have been expected, which undoubtedly indicates that the respondent did not act with the diligence required of it as the controller of such personal data, since it had not foreseen reasonable security measures based on the possible estimated risks established by the aforementioned provision, among which was undoubtedly the provision of instructions and the establishment of an appropriate protocol to prevent employees and representatives acting on behalf of the respondent entity from sending these mass emails without using the blind carbon copy function.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/19

A situation that seems not to have been addressed currently, given that the respondent does not allege or prove having implemented any new security measures aimed at preventing the sending of new emails addressed to more than one recipient without using the blind carbon copy functionality.

In conclusion, in light of the proven facts in this sanctioning procedure, it is considered that the known facts violate the provisions established in Article 32 of the GDPR, for failing to foresee adequate security measures against the risk of unlawful disclosure posed by sending emails to multiple recipients without using the blind carbon copy functionality.

VIII

Classification and qualification of the infringement of Article 32 of the GDPR

By virtue of what is indicated in the previous legal basis, in accordance with the proven facts in this sanctioning procedure, it is considered that the known facts constitute an administrative infringement for violation of Article 32 of the GDPR, for failing to establish adequate security measures that would prevent breaches such as the one produced in this case.

The aforementioned infringement of Article 32 of the GDPR constitutes the commission of an infringement classified in Article 83.4 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" provides the following (the underlining is ours):

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to

a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

5) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)" For the purposes of the limitation period for this infringement, Article 73 "Serious infringements" of the LOPDGDD indicates:

"According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following shall be considered serious and shall be subject to a two-year limitation period: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following: ...

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security appropriate to the risk of processing, in the terms required by Article 32.1 of Regulation (EU) 2016/679."

IX

Sanction for the infringement of Article 32 of the GDPR

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/19

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment in the initiation agreement of the sanctioning procedure, and without prejudice to what results from the instruction, it is appropriate to graduate the sanction to be imposed according to the criteria established in Article 83.2 of the GDPR and Article 76 of the LOPDGDD.

In this case, the following aggravating circumstances can be applied:

(i)

That of Article 83.2.a), referring to the "nature, gravity, and duration of the infringement," it should be noted that we are dealing with an essential obligation to be fulfilled by all data controllers, especially when carrying out mass processing operations, as in the present case, having been established that a basic and widely known measure has been breached, namely the use of blind carbon copy (BCC) to send mass emails. This measure does not require technical complexity for implementation, and all employees of the entity should be aware of it to operate with personal data.

(ii)

The one provided for in Article 83.2.b of the GDPR, "the intent or negligence in the infringement," since every data controller must be aware of their duty to foresee adequate technical and organizational measures to protect the security and confidentiality of the personal data they process, given the Principle of Proactive Responsibility of Article 24 of the GDPR, being aware and analyzing the various risks arising from the processing of this data and its impact on the rights and freedoms of the data subjects. It is understood that there is negligence in the sense established by the Supreme Court, which has already been mentioned previously.

(iii)

The one set out in Article 76.2.b) of the LOPDGDD: "The link of the infringer's activity with the processing of personal data," since the entity in question is dedicated to providing legal and economic advisory services to companies and individuals, which is a professional activity subject to the duty of confidentiality regarding the individuals registered on its payment portals, where numerous personal information related to its participants is collected.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD allows for the initial setting of the fine at €500 (FIVE HUNDRED EUROS) regarding the infringement committed by violating the provisions of Article 32 of the GDPR.

X

Adoption of corrective measures

Once the infringements have been confirmed, it is appropriate to impose on the responsible party the adoption of adequate measures to adjust their actions to the regulations mentioned in this act, in accordance with what is established in the aforementioned Article 58.2.d) of the GDPR, according to

which each supervisory authority may “order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified time frame...”

The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided in Article 83.2 of the GDPR.

In this case, it is appropriate to agree on the following measure: the party being claimed must establish and demonstrate to this administration within 1 month the organizational and technical measures necessary to prevent the future sending of emails with multiple recipients, using the “BCC” functionality or any other that prevents the email address of each recipient from being known by the others.

Among others, it must be demonstrated that protocols have been established and instructions have been provided to all members who send electronic communications on behalf of the entity regarding the necessity of using the blind carbon copy functionality and ensuring the confidentiality of the personal data for which they are responsible.

It is warned that failure to comply with the possible order to adopt measures imposed by this agency in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Articles 83.5 and 83.6, which may motivate such conduct to open another sanctioning administrative procedure.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established, the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on COYARE SLU (Bufete-RA), with NIF B12931754:

- A fine of €2,000 (TWO THOUSAND EUROS) for an infringement of Article 5.1.f) of the GDPR, classified in Article 83.5 of the GDPR.

- A fine of €500 (FIVE HUNDRED EUROS) for the commission of an infringement of Article 32 of the GDPR, classified in Article 83.4 of the GDPR.

SECOND: TO ORDER COYARE SLU (Bufete-RA), with NIF B12931754, that pursuant to Article 58.2.d) of the GDPR, within 1 month from the date this resolution becomes final and enforceable, to demonstrate compliance with the following measures:

“Establish and demonstrate to this administration within 1 month the organizational and technical measures necessary to prevent the future sending of emails with multiple recipients, using the ‘BCC’ functionality or any other that prevents the email address of each recipient from being known by the others.”

THIRD: TO NOTIFY this resolution to COYARE SLU (Bufete-RA).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/19

FOURTH: This resolution shall be enforceable once the period for filing the optional appeal for reconsideration (one month from the day following the notification of this resolution) has expired without the interested party having exercised this right. The sanctioned party is warned that they must comply with the imposed sanction once this resolution is enforceable, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account No.

IBAN: ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX), opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed in the executive period.

Upon receipt of the notification and once enforceable, if the date of enforceability falls between the 1st and 15th of each month, inclusive, the deadline for making the voluntary payment will be until the 20th

of the following month or the next business day thereafter, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second month following or the next business day thereafter.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file an appeal for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and paragraph 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by writing to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

19/19

938-16012024

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es